

SOC 2, Audits & Third-Party Risk

What SOC 2 Is

System and Organization Controls 2 (SOLSKI 2) – for service organizations (SaaS), an auditor attestation over 5 Trust Service Criteria (TSC):

- Security – protection vs unauthorized access/data loss (ALWAYS in scope)
- Availability
- Confidentiality
- Processing Integrity
- Privacy

§ Security leads: CCF (Common Criteria) – CC 5.2, CC 6.1 etc. are the specific controls the auditor checks.

The Audit Ritual

SOC 2 Type I = design check: "controls exist at a point"

SOC 2 Type II = operating check: "controls worked over 3-12 months" (evidence!)

Auditor = third-party CPA-type firm; samples evidence; walks your TEAMS

Every control = evidence trail:

Control: "MFA enabled on all admin access"

Evidence: policy doc + screenshot of IdP MFA enforcement + access review log + training record

The Evidence Fabric (the part analysts live)

Companies "absorb" SOC 2 via their operations:

Logs (from your SOC/M12 telemetry!)

Reports (of the vuln-scan monthly, of incidents)

Access review records, training completion, patch history (M15)

Your work product IS the audit evidence. That's why good operations make audits easy.

Third-Party Risk Management (TPRM)

You outsource = you inherit their risk:

Vendor questionnaire – controls, certifications, breach history

Assess (tier by data criticality)

Contract – the SLA, incident notification, liability

Review on a cycle + re-assess after incidents

Monitor – provider's SOC 2 report (ask to read it!), breach disclosures

Key question for any SaaS you adopt: "What access does their team have to MY data, and what's their breach-notification SLA?" If they can't answer – risk flag.

The Auditor's Question Pattern

The auditor doesn't just ask "do you have X?" – they ask:

Show me the config

Show me the review that happened

Show me the evidence it's monitored

What would happen if someone left? (offboarding evidence!)

Career note: 'compliance' roles love people who understand the *operations* behind the evidence. The analyst who automates evidence collection is a compliance star.